SOUTENANCE · TITRE ISRC — INGÉNIEUR SYSTÈMES, RÉSEAUX ET CYBERSÉCURITÉ

Migration et sécurisation du système d'information de KHS Bank

Projet mené par MOM-TECH — de l'audit à la GED sécurisée

Julien Junior NGONO MESSI · IEF2I

[Date de passage]

Plan de la présentation

1. **Les acteurs**
   KHS Bank, client · MOM-TECH, prestataire
2. **Le cahier des charges**
   objectifs, contraintes, résultats attendus, délais
3. **Les actions réalisées**
   gestion de projet, audit, solutions, maquette Packet Tracer, migration
4. **Focus : la GED sécurisée**
   démonstrateur et démonstration en direct
5. **Synthèse et conclusion**
   bilan financier, recette, perspectives

Le client : KHS Bank

≈ 920	2004	14 M€	2 sites
collaborateurs (780 Paris · 140 Lyon)	création établissement agréé ACPR	budget annuel SI	Paris La Défense · Lyon

Un SI vieillissant et hétérogène

- Postes sous Windows 8
- Messagerie Exchange 2013
- Base SQL Server 2012 (application KHS-Core)
- Liaison VPN unique entre les sites
- Ni SOC, ni PRA/PCA formalisé

Sous forte pression réglementaire

- ACPR · DSP2 · PCI-DSS · RGPD
- Secret bancaire
- Aucune interruption tolérée sur les moyens de paiement
- Pilotage : DSI + Direction Conformité & Sécurité

Le prestataire : MOM-TECH

Cybersécurité

Audit, SOC/SIEM, PRA/PCA, identités et accès, conformité, GED sécurisée

Cloud & infrastructure

Architecture réseau, virtualisation, haute disponibilité, cloud hybride ou souverain

IA & données

Détection d'anomalies et de fraude, analyse comportementale couplée au SOC

Équipe projet : 4 ingénieurs · 2 sous-équipes · démarche ITIL v4

- **Sous-équipe Réseau & Sécurité** — audit réseau, architecture, pare-feu, SOC
- **Sous-équipe Systèmes & Cloud** — virtualisation, stockage, Microsoft 365, migration
- **Chef de projet** — référent MOM-TECH au sein de la DSI de KHS Bank

Le cahier des charges

Objectif	Traduction
Fiabiliser	Redondance, PRA/PCA, haute disponibilité
Sécuriser	RGPD / ACPR / DSP2 / PCI-DSS, SOC, IAM, GED
Moderniser	Microsoft 365, parc harmonisé, sites unifiés
Maîtriser les coûts	Parc et licences rationalisés
Accompagner	Formation, communication, risques humains

Contraintes

- **Réglementaire** — RGPD, ACPR, DSP2, PCI-DSS
- **Continuité** — aucune interruption totale
- **Organisation** — 2 sites, 920 utilisateurs
- **Méthode** — ITIL v4 obligatoire
- **Budget** — 14 M€ / an

Délai et évaluation

26 semaines : du 5 janvier au 26 juin 2026
Évaluation par recette lot par lot, avec procès-verbal

Gestion de projet et démarche ITIL v4



5 janvier 2026 → 26 juin 2026 · 26 semaines

Outils de pilotage

PBS (livrables)

WBS (tâches)

OBS (organisation)

Matrice RACI

Diagramme de Gantt

Maîtrise des risques

Registre des risques évalué (probabilité × impact)

Marge de 10 % pour aléas

Priorisation des constats élevés en début de déploiement

ITIL v4

4 dimensions appliquées

Chaîne de valeur du service

Pratiques clés : changement, incidents, amélioration continue

Principes directeurs

L'audit de l'existant : 14 constats critiques

Réseau (R1–R5)

- Switch cœur unique
- Pare-feu unique, absent à Lyon
- VPN inter-sites unique
- FAI unique par site
- Aucune segmentation / DMZ

Systèmes (S1–S8)

- Baie de stockage unique
- Sauvegardes sans copie externe
- SQL Server 2012, Exchange 2013 en fin de support
- Windows 8 sur les postes
- Aucun RPO/RTO formalisé

Cybersécurité (C1–C8)

- Pas de SOC/SIEM
- Pas de MFA (DSP2)
- Pas de PRA/PCA
- Pas d'EDR
- Documents sensibles non classifiés, sans GED
- Comptes à privilèges non gérés

3 axes : redondance · détection et continuité · protection des données sensibles

Les solutions : trois piliers technologiques

Réseau

Cisco Catalyst 9000

Fortinet FortiGate en HA

VLAN, DMZ, double lien FAI

(Lots A, E)

Virtualisation & PRA/PCA

VMware vSphere HA/DRS

Veeam, règle 3-2-1-1

RPO / RTO définis

(Lots G, 1, 3)

Identité & sécurité

Microsoft 365 E5, Entra ID

MFA, Defender, Purview

Sentinel : SIEM / SOAR

(Lots C, D, F)

Lot	Objet	Constats traités
A	Architecture réseau, DHCP/DNS	R1 – R7
C	Microsoft 365 + Entra ID, MFA conditionnel	S5, C2
F	Audit de sécurité + GED sécurisée + comptes à privilèges	C2, C5, C6, C8
G	PRA / PCA	S1, S2, S8, C3

Architecture cible et plan de migration

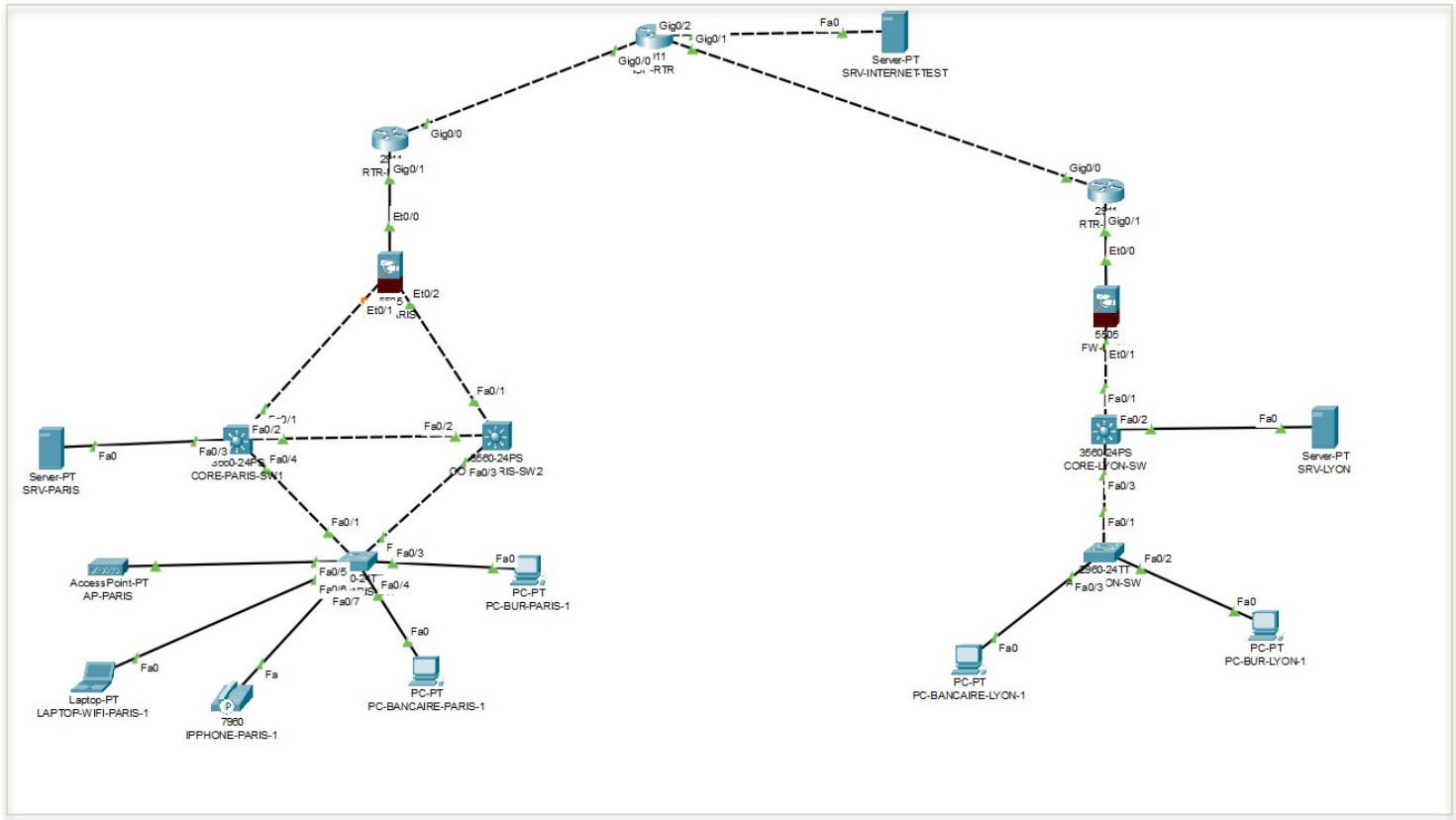
1. Aucun point de défaillance unique
2. Isolation stricte des flux bancaires (VLAN, DMZ, filtrage applicatif)
3. Security by design : identité, chiffrement, journalisation, détection

Migration en coexistence progressive — 7 étapes



Résultat : aucune interruption des services bancaires pendant toute la durée du projet

Maquette Cisco Packet Tracer : la preuve par la pratique



Paris (siège) à gauche · Lyon à droite · FAI simulé au centre

- **20 équipements** — 2 sites, Cisco
- **6 VLAN** — bureautique, bancaire, serveurs, invités, VOIP, management
- **Plan VLSM** — identique au dossier
- **HSRP** — 2 cœurs L3 à Paris, passerelle virtuelle
- **ASA 5505 + NAT + ACL** — invités isolés du LAN
- **Tunnel GRE** — inter-site, équivalent du VPN du dossier

Compétences C07 · C08 : routage, VLAN, routage inter-VLAN, redondance du cœur

Maquette : tests de résilience et de sécurité

Test	Action	Résultat attendu
PT11	Éteindre le cœur actif pendant un ping continu	Quelques paquets perdus, le second cœur prend le relais (HSRP)
PT12	Cœur 1 éteint : ping vers Internet	Le trafic passe par le cœur 2, relié au pare-feu
PT04	Ping du VLAN invités vers le LAN interne	Échec : bloqué par l'ACL des invités
PT05	Ping du VLAN invités vers Internet	Réponse : l'ACL ne bloque que le LAN
PT07	Ping Paris → Lyon	Réponse via le tunnel GRE, sans NAT
PT10	Ping depuis Internet vers l'adresse du pare-feu	Échec : aucune règle n'autorise l'entrant

Simplifications assumées : un pare-feu par site (pas de cluster HA) · un FAI simulé par site · GRE à la place d'IPsec · un poste par VLAN · équivalents Packet Tracer des Catalyst 9300 et FortiGate (absents du catalogue)

Focus : la GED sécurisée (Lot F)

Exigence du Lot F	Constat	Mécanisme du démonstrateur
Classification (public interne / restreint / confidentiel)	C5	Colonne classification, appliquée par la base (RLS)
Accès par rôle (rédacteur, validateur, admin, auditeur)	C5, C8	Règles RLS par rôle et par département
Authentification forte	C2	Double authentification TOTP obligatoire
Workflow dépôt → vérification → validation → publication	C5	Fonction transactionnelle côté base
Journal d'audit immuable	C5	Déclencheur PostgreSQL : aucune modification possible
Archivage réglementé	C17	Scellé SHA-256, lecture seule définitive

Production : SharePoint + Purview · Démonstrateur : Next.js + Supabase/PostgreSQL + Vercel

Principe : la sécurité est dans la base de données



RLS : qui voit quoi

Rôle + département + classification + organisation, évalués par PostgreSQL à chaque requête

MFA imposée par la base

Sans code TOTP (niveau aal2), aucune table n'est lisible, même par appel direct à l'API

Audit immuable

Un déclencheur refuse tout UPDATE ou DELETE, même avec la clé de service

Démonstration en direct : le parcours d'un document



Ce qu'on prouve

Un lecteur ne voit pas un document confidentiel d'un autre département

Sans code TOTP, aucune donnée

L'archivé ne peut plus être modifié

Authenticité

Le PDF signé porte un QR code

Page publique /verifier : le fichier est reconnu ou refusé

Le contenu n'est pas divulgué

Traçabilité

Courrier arrivé numéroté, scanné, remis

Décharge de réception au départ

Journal consultable par l'auditeur, non modifiable

Courrier physique et multi-organisation

Courrier arrivée

Enregistrement sans ouvrir le pli

Numéro ARR-2026-000123

Récépissé PDF, numérisation, remise avec accusé

Plis personnels jamais décrits ni scannés

Courrier départ

Demande d'expédition depuis un document validé

Numéro DEP-…, bordereau, relances

Accusé prouvé par une décharge

Conservation : aucune destruction automatique

Multi-organisation

Un code, plusieurs organisations

Colonne organisation posée par la base

Branding par variables d'environnement

KHS Bank · Agence API

Validation : 33 migrations rejouées sans erreur · 169 + 15 tests SQL du courrier · parcours automatisé de 42 contrôles

Bilan financier

≈ 4,8 M€

investissement initial (CAPEX)
marge de 10 % pour aléas incluse

≈ 1,5 M€/an

fonctionnement récurrent (OPEX)

≈ 11 %

du budget annuel de 14 M€

Poste	Coût
Virtualisation et stockage (4 hôtes ESXi, 2 baies SAN, Veeam)	900 000 €
Réseau (Cisco Catalyst, FortiGate HA, câblage)	780 000 €
Postes clients (920) et infrastructure VDI	650 000 €
Licences Microsoft 365 E5 — 1re année	629 280 €
Prestations d'ingénierie MOM-TECH (4 ingénieurs × 6 mois)	480 000 €

Astreinte SOC 24/7 : 420 000 € par an, premier poste de fonctionnement après les licences

Recette : conformité vérifiée lot par lot

Test	Résultat attendu	Statut
Bascule automatique du cœur de réseau	Aucune coupure perceptible	✔️ Conforme
Bascule du lien VPN principal vers le secours	Reprise < 30 s	✔️ Conforme
Arrêt d'un hôte du cluster VMware	RTO ≤ 30 min	✔️ Conforme
Bascule Always On de KHS-Core	RTO ≤ 1 h · RPO ≤ 15 min	✔️ Conforme
Connexion sans second facteur	Accès refusé (MFA obligatoire)	✔️ Conforme
Injection d'un événement d'authentification suspecte	Alerte Sentinel en moins de 5 min	✔️ Conforme
Envoi externe d'un document confidentiel	Blocage par la politique DLP	✔️ Conforme

12 tests en extrait, tous conformes · procès-verbal de recette signé · aucune interruption des services bancaires

Conclusion et perspectives

Objectif	Résultat
Fiabiliser	Plus aucun point de défaillance unique
Sécuriser	MFA, SOC, GED sécurisée, conformité démontrée
Moderniser	Microsoft 365, Windows 11, VOIP unifié
Maîtriser les coûts	≈ 11 % du budget annuel
Accompagner	Formation exécutée, référents désignés

14 constats critiques traités · 0 interruption de service

Perspectives

- IA du SOC étendue à la lutte anti-fraude
- Évaluation d'un cloud souverain
- GED : authentification unique (Entra ID), DLP, hébergement maîtrisé
- Veille technologique continue (contrat de maintenance)

Merci de votre attention

Questions du jury